

Bartell Ltd Incident Report

Scenario: TryHackMe "Carnage"
Prepared by: Head SOC Department
Name: Sharon Kipsang
Date of report: 15 August 2026

1. Executive Summary

On 24 September 2021, a user on the machine "DESKTOP-IOJC6RB" downloaded and opened a file disguised as a document, which was actually a booby-trapped Excel workbook. This follows a highly deceptive phishing email. Although the message appeared to come from a trusted contact, the contact's email seems to have been hijacked by attackers to send a malicious delivery link.

On opening an attachment, silently installed malware, which then contacted three different servers on the internet controlled by the attacker. Around 17 minutes after the infection, the machine began contacting roughly 30 different mail servers around the world in quick succession — behaviour consistent with the machine being used to send spam or test stolen email logins, likely as part of a wider criminal spam operation rather than a targeted attack on this organisation specifically.

No evidence found that the attacker reached the domain controller, stole domain-wide credentials, or moved to other machines; these checks were run specifically and came back clean. However, the workstation itself is fully compromised, the malware had 20+ minutes of unsupervised access, and we cannot rule out that further malicious tools were installed beyond what we can see in network traffic alone.

What happens now: the affected workstation should be isolated and rebuilt rather than "cleaned", the user's password should be reset, and the internet addresses used by the attacker should be blocked across the organisation immediately. Full details, evidence, and a longer-term action plan are set out below.

2. Scope & Data Sources

This investigation is based on a single artefact: a full network packet capture ("**carnage.pcap**") covering approximately 21 minutes of traffic to and from one workstation.

No disk image, memory dump, antivirus/EDR logs, or email server logs were provided, so this report describes what could be reconstructed from network traffic alone.

Where a conclusion depends on evidence we did not have, it is flagged explicitly.

Artefact	What it can tell us	What it cannot tell us
• carnage.pcap (full packet capture, 56 MB) • 70873 packets. • Time: 16:43:42–17:04:53 UTC • Date: 24 Sep 2021	• Every DNS lookup, HTTP request/response, and unencrypted protocol exchange (LDAP, Kerberos, SMB, DCE/RPC) between the workstation and the domain controller and the internet. • Precise timing and volume of every connection, even encrypted ones.	• The contents of any TLS-encrypted session (the majority of this traffic). • What actually happened on the host's disk, memory, or registry. • Anything before 16:43:42 or after 17:04:53. • Who was physically at the keyboard versus the malware acting on its own. • Whether any of the outbound mail connections succeeded.

Key entities identified in the capture:

- Domain: GOINGFORTUNE.COM
- Domain controller: GOINGFORTUNE-DC — 10.9.23.5
- Affected workstation: DESKTOP-IOJC6RB — 10.9.23.102
- Logged-on user: maya.rudolph

3. Timeline of Events (all times UTC, 24 September 2021)

Time (UTC)	Event
16:43:42	Packet capture begins. Workstation DESKTOP-IOJC6RB (10.9.23.102) on the GOINGFORTUNE.COM domain, logged on as maya.rudolph, exchanging normal logon/GPO traffic with the domain controller GOINGFORTUNE-DC (10.9.23.5).
16:44:38	Browser sends HTTP GET to attirenepal.com for /incidunt-consequatur/documents.zip. A 198 KB ZIP is returned (SHA256 77229c74...).
16:44:38	ZIP is opened, revealing chart-1530076591.xls - a macro-enabled Excel 4.0 (XLM) "chart" lure with an Auto_Open macro and obfuscated hex-encoded formulas (SHA256 2ea1b06d...).
16:44:44	Host performs DNS lookups for three random-looking subdomains of goingfortune.com; all return NXDOMAIN, followed by LLMNR/NBT-NS fallback for the same names. Pattern consistent with a sandbox/DNS-resolvability check used by downloader malware.

Time (UTC)	Event
16:46:15	First outbound beacon: repeated HTTP POST requests to maldivehost.net (208.91.128.6) with base64/XOR-obfuscated URI paths, roughly every 25 seconds. This is assessed as the malware's primary loader/C2 check-in. Continues until 16:56:25.
16:53:23	Second channel opens: repeated short TLS sessions to securitybusinpuff.com (185.125.204.174:8080), continuing intermittently until 17:00:00 — a pattern consistent with a beaconing implant delivered by the loader.
16:55:07	Third channel opens: repeated HTTP requests to 185.106.96.158(survmeter.live) that forge the Host header as obsp.verisign.com and request paths like /gscp.R/<token>. The server replies HTTP 200, Content-Type application/obsp-response, with an empty body — a known technique for disguising C2 beacons as routine certificate-revocation checks.
17:00:03	Host queries api.ipify.org (an external "what is my IP" service) — commonly done by malware immediately before an outbound spam or credential-testing run.
17:01:01 – 17:04:49	Host opens outbound connections to 30+ distinct external mail servers worldwide (Gmail relay, AT&T, GoDaddy/SecureServer, Gandi, 1&1, and numerous small regional providers) on ports 25/465/587/995/2525. Consistent with the host being enrolled in a spam/mass-mail or credential-testing operation. Contents are not visible — sessions are encrypted (implicit TLS or STARTTLS).
17:04:53	Capture ends. The mail-server connection activity is still ongoing at this point though its outcome is not captured in this data set.

4. Investigation & Analysis

4.1 Initial access — malicious macro workbook

The ZIP downloaded from attirenepal.com contained chart-1530076591.xls, an OLE Compound File. Static analysis (oletools/olevba) identified an Excel 4.0 (XLM) macro sheet — hidden from the user by default — containing an Auto_Open macro, string obfuscation via CHAR()/hex-encoding, and use of FORMULA.FILL, a technique used to build up malicious formulas at runtime rather than storing them in the clear. This is a well-established phishing pattern: a disguised "invoice" or "chart" spreadsheet that runs code the moment it is opened, with no further user interaction required (beyond the usual "Enable Content" click).

We were not able to fully de-obfuscate the exact second-stage download command from static analysis of the macro alone — this is a limitation of the tooling available, not a dead end in the evidence. However, the network capture shows the first C2 beacon starting only 6 seconds after the ZIP finished downloading, which ties macro execution directly to the C2 activity that follows.

4.2 Command-and-control activity

Three distinct outbound channels were identified after the document was opened:

- maldivehost.net — regular HTTP POST requests roughly every 25 seconds, with URI paths that decode from base64 to short binary/XOR-obfuscated blobs. This is assessed as the malware's primary check-in / loader gate.
- securitybusinpuff.com — repeated short-lived TLS sessions to a non-standard port (8080), a pattern typical of a beaoning implant delivered as a second-stage payload.
- survmeter.live (contacted via IP 185.106.96.158) — HTTP requests that forge the Host header to read "ocsp.verisign.com" and request paths designed to look like certificate-revocation checks. The server's replies carry Content-Type: application/ocsp-response but an empty body, which is not how a real OCSP responder behaves. This is a known camouflage technique intended to blend malicious beacon traffic in with the background noise of routine TLS certificate checking.

Together, these three channels indicate a loader-type infection that establishes multiple, redundant lines back to the attacker — consistent with commodity malware loader behaviour (e.g. the IcedID/BokBot family), assessed on the pattern of a macro-document dropper, fake-OCSP camouflaged beaoning, and a disposable cPanel-hosted gate. This is a behavioural assessment, not a confirmed family match — no second-stage binary was recovered from the capture for hash-based confirmation.

4.3 Post-infection outbound spam / mail activity

Starting at 17:00:03, the host queried api.ipify.org, a free "what is my public IP" service.

One minute later it began opening connections to over 30 distinct external mail servers across many unrelated organisations and countries (including Gmail's relay, AT&T, GoDaddy/SecureServer, Gandi, and numerous small regional mail providers) on SMTP-family ports (25, 465, 587, 995, 2525), all within about four minutes. A legitimate workstation has no reason to talk directly to dozens of unrelated mail servers — that is normally the job of a single corporate mail relay. This pattern is consistent with the infected host being used as a spam or mail-credential-testing bot.

The contents of these sessions since they are TLS-protected could not be inspected, so we cannot confirm from this data whether real emails were sent, whether stolen credentials were used, or what the target recipients were. This activity was still in progress when the capture ended.

4.4 Ruled out: Active Directory compromise via DCSync

Because directory-replication abuse ("DCSync") is one of the most damaging things an attacker can do from a compromised workstation, we specifically checked for it.

All drsuapi remote-procedure-call traffic between the workstation and the domain controller was reviewed by operation number; only DsBind, DsUnbind, and DsCrackNames calls were observed, all within the first 40 seconds of the capture, matching normal Windows domain-logon behavior. The specific call abused by tools such as Mimikatz or secretsdump to pull password hashes (DRSGetNCChanges) was never invoked. No broad, BloodHound-style LDAP enumeration was observed either. We assess with reasonable confidence that no Active Directory credential-harvesting occurred within the capture window.

4.5 Ruled out: the 15 MB transfer to 23.111.114.52

A single connection to 23.111.114.52 on the unusual port 65400 stood out for its size (15 MB) and duration (over 6 minutes) — an easy candidate to mistake for data exfiltration or a large payload download.

On inspection, the packet contents contained BitTorrent/peer-exchange-style records (peer IDs and IP addresses), and DNS activity in the same window resolved several *.prod.do.dsp.mp.microsoft.com names. This matches Windows Delivery Optimization, Microsoft's legitimate peer-to-peer Windows Update distribution feature, not attacker activity. Flagged and ruled out rather than pursued further.

4.6 Not resolvable from this data

The following could not be determined from packet capture alone and would require host-based evidence (EDR telemetry, disk image, or memory capture) to resolve:

- The exact contents/commands exchanged over the TLS-protected C2 channels (securitybusinpuff.com, survmeter.live).
- Whether a persistence mechanism (scheduled task, registry run key, service) was installed on the host.
- Whether the outbound mail-server connections succeeded, and if so, what was sent and to whom.
- The referring page or delivery mechanism (e.g. phishing email) that led the user to attirenepal.com — the browser sent no Referer header, and no earlier mail traffic delivering a link was present in this capture window.

5. Indicators of Compromise

Ready to feed into a blocklist / SIEM watchlist:

Type	Indicator	Context
Domain	attirenepal.com	Hosted the initial malicious ZIP/XLS download
Domain	maldivehost.net	Primary loader/C2 check-in (HTTP POST, obfuscated paths)
Domain	securitybusinpuff.com	Secondary beacon channel over TLS on port 8080
Domain	survmeter.live	Third channel; disguises itself with Host: ocsf.verisign.com
IP	85.187.128.24	Hosted attirenepal.com / documents.zip
IP	208.91.128.6	maldivehost.net C2 gate
IP	185.125.204.174:8080	securitybusinpuff.com beacon endpoint
IP	185.106.96.158	survmeter.live / fake-OCSP beacon endpoint

Type	Indicator	Context
File / hash (SHA256)	77229c744a0b1470afc7989a774cfe821386c11c0165e7e3fb5e9897a789a8cb	documents.zip
File / hash (SHA256)	2ea1b06de7bc93f2165db2ac29a9c964716f17415472497b31be4062bb639240	chart-1530076591.xls (malicious macro workbook)
File / hash (MD5)	4e4b24f9d35dad7270e797b3b382a98b	chart-1530076591.xls
Filename	chart-1530076591.xls / documents.zip	Lure filenames - worth an EDR/email-gateway retro-hunt org-wide
Account	maya.rudolph	User logged on to the affected workstation at the time of infection
Host	DESKTOP-IOJC6RB (10.9.23.102)	Compromised workstation
User-Agent	Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/93.0.4577.82 Safari/537.36 Edg/93.0.961.52	Browser used for the initial malicious download

6. Containment & Recommendations

6.1 In the next hour

- Isolate DESKTOP-IOJC6RB from the network immediately (network quarantine / disable the switch port), or at minimum block all outbound internet access from it.
- Reset the password for maya.rudolph and revoke any active sessions/tokens; check whether the same password was reused on other systems or personal accounts.
- Block the domains and IPs in the IOC table above at the firewall, web proxy, and DNS resolver level across the whole estate, not just this host.
- Check the organisation's outbound mail reputation / blacklist status - mass connections to dozens of external mail providers can get the organisation's IP range blacklisted.
- Preserve this pcap and, before doing anything else to the machine, take a forensic disk image and memory capture. Network data alone cannot tell us if anything persisted or if data left the host by another channel.

6.2 Longer-term

- Rebuild the workstation from a known-good image rather than attempting to "clean" it. Loader-type malware like this routinely fetches additional modules; we cannot be confident the spam module was the only thing installed.
- Block Excel 4.0 (XLM) macros organisation-wide via Group Policy / Microsoft 365 admin settings — this single control would have stopped this specific infection chain at the source.
- Add egress filtering / DNS sinkholing for newly-registered or low-reputation domains — all four attacker domains in this incident were young, disposable-looking domains on shared/bulletproof-style hosting.
- Run a brief phishing-awareness reminder for staff: this was a "fake invoice/chart" lure delivered as a direct file download, not an attachment — to remind users that unexpected Office files from web links should not be opened, even from Enable Content prompts.

6.3 Detection ideas (would have caught this)

Spam-bot behaviour: alert when a single internal host opens outbound connections to more than 5 distinct external mail-server IPs (destination port 25, 465, 587, or 2525) within a 10-minute window. Legitimate workstations never talk SMTP directly to more than one or two mail relays — that is the corporate mail server's job. This rule would have fired at approximately 17:01 UTC, about 17 minutes after the initial infection and well before the loader had time to fetch further modules.